UNIT 3 · TOPIC 3.5

Detecting Network Attacks

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following is an automated security tool whose primary function is to monitor network traffic and generate an alert when a known attack signature is matched?

○ A. Password manager

● **B. Network-based Intrusion Detection System (NIDS)**

○ C. File compression utility

○ D. DHCP server

Correct answer: B

Why: A NIDS passively monitors network traffic at a capture point, compares packets against a database of known attack signatures, and raises alerts when matches are found. It is one of the primary automated tools used to detect network attacks. The other options serve credential management, file size reduction, and IP address assignment functions respectively, none of which involve traffic inspection or attack detection.

*Why the others are wrong: **A**, Password managers store and retrieve credentials; they have no network-monitoring capability. **C**, File compression tools reduce file size; they do not inspect or analyze network traffic. **D**, DHCP servers assign IP addresses to hosts; they do not analyze traffic content for attack indicators.*

2. A network administrator wants to monitor all inbound traffic at a corporate gateway and automatically block packets that match known malicious patterns, not just alert on them. Which tool should the administrator deploy?

○ A. Intrusion Detection System (IDS)

○ B. Network packet analyzer (sniffer)

● **C. Intrusion Prevention System (IPS)**

○ D. Network Address Translator (NAT)

Correct answer: C

Why: An IPS sits inline with network traffic and can actively block or drop packets that match attack signatures or exceed anomaly thresholds, it is a preventive control. An IDS is a detective-only control that generates alerts but does not block traffic. A sniffer captures packets for analysis without taking any blocking action. A NAT device translates IP addresses and has no intrusion detection or prevention function.

*Why the others are wrong: **A**, An IDS alerts administrators but cannot block traffic on its own; it is passive, not active. **B**, A sniffer captures traffic for later analysis; it takes no automated action against malicious packets. **D**, NAT translates between private and public IP address spaces; it is not a security detection or prevention tool.*

3. Which of the following correctly identifies the key difference between signature-based and anomaly-based intrusion detection?

○ A. Signature-based detection can identify zero-day attacks; anomaly-based detection cannot.

○ B. Anomaly-based detection is always less accurate than signature-based detection.

● **C. Signature-based detection matches traffic against known attack patterns; anomaly-based detection flags deviations from an established behavioral baseline.**

○ D. Signature-based detection works without any prior configuration; anomaly-based detection requires hardware support.

Correct answer: C

Why: Signature-based IDS compares traffic or behavior against a database of pre-written rules for known attacks; it is effective and low in false positives for known threats but blind to novel ones. Anomaly-based IDS learns a baseline of normal behavior and raises alerts for statistical deviations; this allows detection of zero-days but at the cost of more frequent false positives during the baselining period.

*Why the others are wrong: **A**, The opposite is true: anomaly-based detection can surface novel (zero-day) attacks because it does not rely on known signatures. **B**, Accuracy comparisons depend on context; anomaly-based detection excels at novel threats but produces more false positives in some environments. **D**, Both approaches require configuration; neither inherently requires specialized hardware.*

4. A financial services firm frequently faces zero-day exploits targeting its proprietary trading platform. The security team is choosing between deploying a signature-based IDS and an anomaly-based IDS. Which detection method should the team prioritize, and what is the primary justification?

○ A. Signature-based, because it produces fewer false positives and is easier to tune.

● B. Anomaly-based, because it can identify deviations from a behavioral baseline without requiring a pre-existing signature for the attack.

○ C. Signature-based, because it is computationally cheaper and scales better to high-throughput trading traffic.

○ D. Anomaly-based, because it completely eliminates false positives once the baseline is established.

Correct answer: B

Why: Zero-day exploits have no known signatures, so a signature-based IDS cannot detect them. An anomaly-based system establishes a statistical baseline of normal trading-platform behavior and flags deviations, giving it the ability to surface novel attack patterns. Option D misrepresents anomaly-based IDS, it can still generate false positives, particularly when legitimate behavior changes. Options A and C are accurate statements about signature-based IDS but do not address the firm's zero-day threat.

*Why the others are wrong: **A**, Fewer false positives is a genuine advantage of signature-based IDS, but it is irrelevant when the threat is zero-day (no signature exists to match). **C**, Computational cost is a valid operational consideration but not the primary factor when the attack type cannot be signature-detected. **D**, Anomaly-based IDS does not eliminate false positives; legitimate behavioral changes (e.g., new trading strategies) will continue to generate them.*

5. In Scenario 3B, the National Guard network technician must recommend detective controls for a satellite-linked public Wi-Fi network at a disaster shelter. The network must detect both external attacks and misuse by shelter occupants. Which combination of tools best addresses both threat surfaces?

● A. A NIDS for real-time traffic monitoring combined with a SIEM for log aggregation and cross-device correlation.

○ B. Antivirus software installed on each shelter laptop only.

○ C. A perimeter firewall with logging disabled to reduce alert noise.

○ D. MAC address filtering to restrict which devices can join the network.

Correct answer: A

Why: A NIDS placed at the satellite link provides real-time inspection of all inbound and outbound traffic, flagging both external attacks and suspicious internal behavior. A SIEM aggregates logs from the NIDS, the wireless access point, and any other network devices to correlate events that neither tool would surface independently. Antivirus covers only endpoint malware, not network-level attacks. Disabling firewall logging eliminates visibility. MAC filtering restricts access but provides no detection capability once an allowed device is compromised.

*Why the others are wrong: **B**, Antivirus software addresses endpoint threats but cannot monitor network traffic for attack patterns or misuse. **C**, Disabling logging on the firewall removes the event data needed for any detection or forensic analysis. **D**, MAC filtering is an access control, not a detection control; it prevents some unauthorized joins but offers no ongoing visibility into traffic behavior.*

6. A security team's IDS generates 600 alerts per day, the vast majority of which are false positives caused by an internal vulnerability scanner running nightly. Which action best improves the usefulness of the IDS without creating detection blind spots?

○ A. Disable the IDS during the nightly scan window to eliminate the false positives.

○ B. Route the scanner's traffic around the IDS sensor to reduce the alert load.

○ C. Replace the IDS with a next-generation firewall, which generates fewer alerts.

● D. Tune the IDS ruleset to whitelist the scanner's IP address and adjust sensitivity thresholds for its known traffic patterns.

Correct answer: D

Why: Tuning, adding whitelist exceptions for the scanner's known source IP and adjusting rules to de-prioritize its traffic patterns, suppresses false positives without removing the IDS's ability to detect real attacks from the same or adjacent network segments. Disabling the IDS during the scan window creates an obvious attacker opportunity (many attackers exploit maintenance windows). Replacing the IDS with a firewall removes detection capabilities entirely. Rerouting the scanner around the sensor creates a persistent blind spot that an attacker could exploit by masquerading as scanner traffic.

*Why the others are wrong: **A**, Disabling the IDS creates a nightly window without network detection, which sophisticated attackers deliberately time their activity to exploit. **B**, Bypassing the sensor for scanner traffic creates a permanent monitoring gap that an attacker spoofing the scanner's IP could exploit. **C**, Next-generation firewalls serve a different function from IDS; replacing one with the other trades detection depth for access control.*

7. A university deployed a signature-based NIDS campus-wide eighteen months ago. A post-incident review of three recent breaches reveals that in each case the NIDS generated zero alerts during the intrusion. Evaluate the most likely root cause and the architectural change that would most improve detection coverage going forward.

● A. Signature-based detection cannot identify polymorphic or zero-day attacks; layering an anomaly-based detection capability alongside the existing NIDS would best address the coverage gap.

○ B. The NIDS sensor was placed incorrectly; relocating it to the DMZ will prevent future misses.

○ C. The NIDS failed due to insufficient hardware resources; replacing it with an appliance-grade IPS resolves the detection gap.

○ D. The NIDS functioned correctly; the breaches did not involve network-layer activity.

Correct answer: A

Why: A signature-based NIDS that generates zero alerts across three separate intrusions most plausibly failed because the attacks used techniques, zero-day exploits, polymorphic payloads, or living-off-the-land methods, for which no signature existed in the database. A defense-in-depth approach adding anomaly-based detection (behavioral baseline analysis) addresses this gap because it does not require prior knowledge of the attack. Option B conflates sensor placement with detection methodology, a correctly placed signature-based sensor still cannot detect what it has no signature for. Option C conflates performance limitations with detection logic limitations. Option D is conjecture unsupported by the evidence.

*Why the others are wrong: **B**, Sensor placement affects which traffic is visible, but even a perfectly placed signature-based sensor cannot detect a novel attack with no matching rule. **C**, Hardware limitations cause missed packets under high load, but that would produce sporadic misses, not systematic zero alerts across three distinct incidents. **D**, Dismissing the detection failure without evidence contradicts sound incident response methodology and provides no architectural improvement.*

8. A security architect is evaluating two detection approaches for a large enterprise: (1) a NIDS in promiscuous mode on the core backbone, and (2) distributed HIDS agents installed on every endpoint. Which statement most accurately captures the trade-offs between these two approaches?

○ A. NIDS always has lower operational overhead than HIDS because it does not run on production hosts.

○ B. HIDS is strictly superior because it sees all traffic before and after decryption at the endpoint.

● C. NIDS provides broad network-layer visibility but may be blind to encrypted lateral movement; HIDS can inspect host-level activity but introduces endpoint overhead and cannot observe cross-segment traffic without log correlation.

○ D. Once TLS inspection is enabled on the NIDS, HIDS agents become redundant.

Correct answer: C

Why: NIDS at the backbone sees all unencrypted inter-segment traffic with no endpoint overhead, but once end-to-end TLS is in use, payloads are opaque at the network sensor. HIDS agents run on each host and can observe process behavior, file system events, and local authentication logs, and they see decrypted application data, but they consume host CPU and

memory and cannot independently observe another host's activity without log correlation infrastructure. TLS inspection (Option D) adds cost and policy complexity and inspects only perimeter-terminated TLS, not all internal encrypted sessions; it does not eliminate HIDS value for host-local events.

*Why the others are wrong: **A**, Operational overhead for NIDS includes sensor hardware, tap or SPAN configuration, and signature update management; for large-scale HIDS, agent deployment and update management can exceed NIDS overhead at scale. **B**, HIDS agents see local traffic after the OS network stack processes it, but they cannot observe traffic flowing between other hosts without that traffic passing through or being logged on the monitored endpoint. **D**, TLS inspection at a gateway decrypts perimeter traffic but does not cover peer-to-peer internal encrypted sessions or host-local process behavior, so HIDS retains distinct value.*

9. A SIEM monitoring the disaster-shelter network (Scenario 3B) fires an alert at 03:47: a single internal host is generating outbound DNS queries at a rate of one per second, each resolving a unique high-entropy subdomain of the same parent domain. Evaluate what this pattern most likely indicates, and determine which detective control would have surfaced it earliest, before the SIEM correlation fired.

○ A. Normal nightly software update check; no detective control needed; close the alert.

● B. DNS tunneling or C2 beaconing via subdomain randomization; a NIDS with DNS query-rate and entropy anomaly rules would surface it earliest, prior to SIEM correlation.

○ C. A misconfigured recursive DNS resolver producing spurious queries; syslog monitoring alone is sufficient.

○ D. A DNS-based DDoS amplification attack originating from inside the shelter; blocking all outbound UDP/53 permanently resolves the issue.

Correct answer: B

Why: High-frequency outbound DNS queries to unique high-entropy subdomains of a single parent domain is the defining fingerprint of DNS tunneling or C2 beaconing: the attacker encodes data or commands in subdomain labels, avoiding payload inspection of the DNS request body. A NIDS with rules monitoring DNS query frequency, subdomain entropy, and query-to-answer byte ratios would raise this alert at the first few queries, before the SIEM's correlation window accumulates enough events. Permanently blocking all outbound UDP/53 (Option D) would break legitimate DNS resolution for the shelter; rate-limiting and sinkholing the specific parent domain are more appropriate responses. A misconfigured resolver (Option C) produces repeated queries for the same record, not unique high-entropy subdomains.

*Why the others are wrong: **A**, Legitimate update checks query known vendor domains and do not generate unique high-entropy subdomains at one-second intervals. **C**, A misconfigured resolver retries the same domain record; the unique-per-query subdomain pattern is characteristic of deliberately generated randomized identifiers, not resolver retry loops. **D**, Blocking all outbound UDP/53 disables DNS for every shelter occupant; targeted sinkholing or rate-limiting is the appropriate surgical response. Additionally, this is not an amplification attack, amplification exploits open resolvers to flood a victim, which is not the pattern described.*

10. How does an AI-assisted threat detection system differ from a traditional signature-based IDS in its ability to identify unknown attacks?

○ A. AI operates faster than IDS because it uses hardware acceleration.

○ B. AI completely eliminates false positives by automating the analyst response workflow.

● C. AI can detect novel attack patterns by learning from behavioral baselines without requiring predefined signatures for each threat.

○ D. AI is only useful after a human analyst has first identified and labeled the threat manually.

Correct answer: C

Why: AI/ML-based detection systems learn statistical models of normal network or system behavior. Any activity that deviates significantly from the learned baseline is flagged, regardless of whether a signature exists. This allows AI to surface zero-day exploits and novel attack patterns that would be invisible to a signature-based system. AI systems do generate false positives and still benefit from human analyst validation; they are not solely dependent on prior human labeling for inference.

*Why the others are wrong: **A**, Speed is an operational property unrelated to the detection capability difference; both IDS and AI systems can be hardware-accelerated. **B**, AI systems reduce but do not eliminate false positives; behavioral anomalies from legitimate changes*

(new applications, network growth) continue to trigger alerts. ***D****, Supervised ML requires labeled training data initially, but once trained, the model infers independently; it does not require real-time analyst labeling during inference.*

11. A network analyst reviews authentication logs and finds the following pattern: 847 failed SSH login attempts from a single external IP address over a four-minute window, followed by one successful login. Which attack type does this log pattern most directly indicate?

○ A. SQL injection

○ B. Man-in-the-middle attack

○ C. DNS cache poisoning

● D. Brute-force credential attack

Correct answer: D

Why: Hundreds of failed login attempts in rapid succession from a single source targeting an authentication service, culminating in a successful login, is the textbook log signature of a brute-force attack, systematically trying credentials until one succeeds. SQL injection targets database query inputs. A man-in-the-middle attack intercepts communications between two parties and would appear in traffic captures, not authentication logs, as repeated failed logins. DNS cache poisoning corrupts resolver caches with fraudulent records and produces DNS response anomalies, not SSH login failures.

Why the others are wrong: ***A****, SQL injection is directed at database query interfaces (web forms, APIs) and would not appear as SSH authentication events.* ***B****, A MitM attack requires the attacker to position between two communicating parties; it does not generate a pattern of repeated failed authentication from a single external IP.* ***C****, DNS cache poisoning manipulates DNS record responses; it would appear in DNS logs, not SSH authentication records.*

12. Which of the following log artifacts is the most direct indicator that a port scan has been conducted against a network host?

○ A. Large volume of outbound SMTP traffic from a single internal host.

● B. Connection attempts to many sequential or random ports on a single target host from one source IP in a short time window.

○ C. High-rate DNS queries for unique subdomains of a single parent domain.

○ D. Repeated authentication failures on an internal file share from the same user account.

Correct answer: B

Why: A port scan is characterized by rapid connection attempts (SYN packets, ICMP probes, or full TCP connections) across a range of ports on a single target, originating from one source. The goal is to identify which ports are open, revealing services the attacker can target. This pattern is directly visible in firewall or IDS logs as many short-duration or refused connection events to sequential or random destination ports. The other options describe spam distribution (A), DNS tunneling (C), and brute-force authentication attempts (D) respectively.

Why the others are wrong: ***A****, Outbound SMTP volume is associated with spam bots or email data exfiltration, not reconnaissance port scanning.* ***C****, High-rate unique-subdomain DNS queries indicate DNS tunneling or C2 communication, not port scanning activity.* ***D****, Repeated authentication failures on a file share indicate brute-force credential stuffing, not host reconnaissance via port scanning.*

13. The National Guard technician (Scenario 3B) reviews the shelter network's NIDS alerts and finds: a flood of UDP packets targeting port 53 originating simultaneously from 23 different internal host IPs toward the same external destination. Applying detection techniques, which attack type should the technician classify this as, and what is the most appropriate immediate containment action?

○ A. ARP spoofing originating from inside the shelter; enable dynamic ARP inspection on all switch ports.

○ B. SSL stripping attack; enforce HSTS headers on the shelter's web application.

○ C. Brute-force SSH attack; block inbound TCP port 22 at the satellite link perimeter.

● D. DNS amplification attack with internal hosts acting as unwilling participants or bots; restrict outbound UDP port 53 to only the authorized DNS resolver's IP.

Correct answer: D

Why: A simultaneous flood of UDP/53 packets from many internal hosts toward an external target is the pattern of DNS amplification being conducted through (or by) the internal hosts, whether they are bots participating in a DDoS or misconfigured resolvers being abused. Restricting outbound DNS to only the authorized resolver's IP prevents arbitrary hosts from sending DNS traffic externally, stopping their participation in the amplification. ARP spoofing, brute-force SSH, and SSL stripping each involve entirely different protocols and attack mechanisms unrelated to this log pattern.

*Why the others are wrong: **A**, ARP spoofing operates at Layer 2 and would appear as gratuitous ARP broadcasts, not UDP/53 floods directed at an external IP. **B**, SSL stripping intercepts HTTPS connections by downgrading them to HTTP; it would appear in traffic captures as protocol downgrade events, not UDP/53 floods. **C**, Brute-force SSH targets TCP/22 with repeated authentication attempts; the pattern described is UDP/53 originating from internal hosts, not inbound TCP authentication failures.*

14. A SIEM alerts on the following pattern for a single internal host: 18 outbound TCP connections to 18 different external IP addresses, all on port 443, each connection lasting under 3 seconds, occurring over a 90-second window. Without AI assistance, a human analyst must classify this behavior. Which classification is most defensible, and what additional NetFlow evidence would confirm it?

○ A. Normal web browsing; no additional evidence needed.

○ B. Data exfiltration via HTTPS; confirm by looking for large total outbound byte counts per session.

● C. Potential C2 beaconing; confirm by looking for regular time intervals between connections and consistent small payload sizes per session in NetFlow records.

○ D. A port scan; confirm by looking for ICMP echo requests preceding each TCP connection.

Correct answer: C

Why: Short-duration connections to many distinct external IPs on the same port in a short window, especially with regularity, is a behavioral signature of command-and-control (C2) beaconing: the malware checks in with its C2 infrastructure at timed intervals. NetFlow confirmation looks for (1) regular inter-connection timing (periodicity) and (2) consistent small payload sizes per session, distinguishing beaconing from browsing (variable timing, variable payload) and exfiltration (large per-session bytes). A port scan uses connection attempts across many ports on one target, not one port across many targets. Normal browsing would show diverse ports (80, 443, etc.) and irregular timing.

*Why the others are wrong: **A**, Normal browsing would include varied destination ports and irregular timing across sessions; 18 connections all on port 443 in 90 seconds with sub-3-second duration is not typical user browsing behavior. **B**, Data exfiltration would produce large per-session byte counts; the described pattern involves very short sessions, more consistent with small-payload check-ins than bulk data transfer. **D**, A port scan targets many ports on one host, not one port across many separate external hosts.*

15. An AI-powered anomaly detection system flags an internal developer's workstation as exhibiting highly anomalous network behavior. Investigation reveals the developer recently began running containerized microservice test environments that generate substantial inter-service traffic. How should the security analyst use the AI alert alongside manual investigation to correctly classify this event?

● A. Correlate the AI alert with change-management records (was the container deployment authorized?) and container platform logs (does the traffic profile match expected container orchestration behavior?) before classifying the event as benign or malicious.

○ B. Dismiss the AI alert because container environments are well-known sources of anomaly false positives.

○ C. Accept the AI classification immediately and isolate the workstation from the network pending forensic review.

○ D. Escalate directly to the incident response team without further investigation because the AI flagged it with high confidence.

Correct answer: A

Why: AI anomaly alerts require human-in-the-loop validation before classification. The correct process is to: (1) check change-management records to verify the container environment deployment was approved; (2) compare the observed traffic profile against known container orchestration traffic signatures (e.g., Docker or Kubernetes control-plane patterns) using container platform logs. If both align, the anomaly is benign and the AI baseline should be updated. If the traffic does not match expected orchestration behavior or no change record exists, escalation is warranted. Blindly accepting AI output (A, D) leads to unnecessary disruption; dismissing it without evidence (B) suppresses legitimate alerts.

*Why the others are wrong: **B**, Dismissing the alert without evidence-based validation removes the signal that would catch a genuine attack masquerading as container traffic. **C**, Immediate isolation without investigation disrupts the developer's work unnecessarily and may impede a legitimate business function. **D**, High AI confidence does not replace analyst judgment; escalating without evidence-gathering wastes incident response resources and reduces team trust in the detection system.*

16. A threat hunting team analyzes log files from a recently compromised network and reconstructs the following sequence: (1) an internal workstation issued a DNS query for a domain registered 48 hours prior; (2) a TCP/443 connection to that domain was immediately established and maintained; (3) over the following 72 hours, the workstation sent 4.2 GB outbound in small encrypted bursts averaging 6 MB per transfer. Evaluate which attack lifecycle phase this evidence sequence represents, and identify all indicators of compromise (IoCs) present.

○ A. Initial access phase; IoCs present: the DNS query and the newly registered domain only.

○ B. Lateral movement phase; IoCs present: the internal DNS query and the total outbound traffic volume.

● C. Exfiltration phase of an established multi-stage intrusion; IoCs present: domain age under 48 hours (newly registered domain infrastructure), persistent HTTPS C2 communication (beaconing pattern), and large cumulative outbound data transfer volume (4.2 GB).

○ D. Reconnaissance phase; IoCs present: the DNS query only.

Correct answer: C

Why: Three distinct IoCs are present: (1) Domain age, a domain registered 48 hours prior is a strong indicator of purpose-built attacker infrastructure (threat actors often register domains immediately before use to avoid reputation-based blocking); (2) C2 communication, the persistent TCP/443 connection established immediately after DNS resolution indicates an already-implanted C2 channel, not initial access; (3) Low-and-slow exfiltration, 4.2 GB transferred in small encrypted bursts over 72 hours is a deliberate technique to stay under rate-based detection thresholds. This log window represents the exfiltration phase; the initial access and post-compromise persistence phases preceded this observation window. Lateral movement involves host-to-host internal movement, which is not described here.

*Why the others are wrong: **A**, Initial access refers to the attacker's first foothold on the network (e.g., phishing, exploitation). The described logs show an already-established C2 channel and sustained exfiltration, indicating the intrusion is well past initial access. **B**, Lateral movement is the attacker's horizontal movement between internal hosts; the traffic pattern described is all outbound to an external domain, not internal host-to-host. **D**, Reconnaissance involves gathering information about the target before intrusion; an established persistent outbound connection with 4.2 GB exfiltrated is well beyond the reconnaissance phase.*

17. An attacker conducts a slow-and-low data exfiltration campaign, transferring exactly 10 MB of stolen data per day over 90 days, deliberately staying below daily traffic anomaly thresholds. Evaluate the comparative effectiveness of AI-assisted anomaly detection versus daily human log review for detecting this specific attack pattern, and identify the primary reason for the difference.

○ A. Human analysts are more effective because they can apply organizational context that AI models lack when interpreting traffic data.

○ B. Both approaches are equally effective because modern SIEM dashboards surface all traffic anomalies automatically regardless of the detection backend.

○ C. Neither approach is effective; only network segmentation prevents slow-and-low exfiltration from reaching an external destination.

● D. AI-assisted detection is more effective for this scenario because it can maintain continuous behavioral baselines over long time horizons and detect cumulative drift that human analysts reviewing daily snapshots are statistically unlikely to identify.

Correct answer: D

Why: Slow-and-low exfiltration is specifically engineered to defeat human pattern recognition: 10 MB per day falls within normal day-to-day traffic variation visible in any single day's log review. An AI model maintaining a 90-day behavioral baseline detects the gradual drift, the cumulative 900 MB over the campaign, as a statistically significant deviation from the host's established normal even though no single day's transfer exceeds thresholds. Human analysts reviewing daily snapshots lack the cognitive capacity to track 90-day cumulative trends without automated assistance. Network

segmentation (Option C) limits lateral reach but does not prevent exfiltration from an already-compromised host to an external C2. SIEM dashboards display alerts but do not generate them without an underlying detection model.

*Why the others are wrong: **A**, Human contextual judgment is valuable for investigation and response, but it does not help detect a pattern deliberately designed to fall below the human perceptual threshold of a single day's review. **B**, SIEMs surface alerts generated by detection rules or ML models; the alerting capability is only as good as the underlying detection logic. Without a long-horizon anomaly model, the SIEM has no rule to trigger on 10 MB/day transfers. **C**, Network segmentation reduces the attack surface for lateral movement; it does not prevent an already-compromised and permitted host from communicating outbound.*

18. A SOC analyst receives the following log extract from the disaster-shelter network (Scenario 3B):

[03:47:12] SRC=192.168.4.87 DST=8.8.8.8 PROTO=UDP/53 QUERY=a1b2c3d4.maliciousdomain.org
[03:47:13] SRC=192.168.4.87 DST=8.8.8.8 PROTO=UDP/53 QUERY=e5f6g7h8.maliciousdomain.org
[03:47:14] SRC=192.168.4.87 DST=8.8.8.8 PROTO=UDP/53 QUERY=i9j0k1l2.maliciousdomain.org
[03:47:15] SRC=192.168.4.87 DST=8.8.8.8 PROTO=UDP/53 QUERY=m3n4o5p6.maliciousdomain.org

Evaluate what this log pattern represents, which detective control would most effectively surface it before SIEM correlation fires, and what limitation exists in relying solely on a standard perimeter firewall to contain it.

- **● A. DNS tunneling or C2 beaconing via randomized-subdomain encoding; a NIDS with DNS query-rate and subdomain-entropy anomaly rules would surface it earliest; a standard firewall allowing outbound UDP/53 cannot inspect DNS payload entropy and would not block these queries without also breaking all legitimate DNS resolution for shelter users.**
- ○ B. Normal recursive DNS lookups from a misbehaving resolver; a syslog monitor would surface it; firewalls fully contain misbehaving resolvers.
- ○ C. A DNS-based DDoS amplification attack; permanently blocking all outbound UDP/53 is fully sufficient with no limitations.
- ○ D. Normal behavior for a device running automatic security update checks; no detective control needed; close the alert.

Correct answer: A

Why: One-second-interval DNS queries for unique high-entropy subdomains of a single parent domain is the defining technical signature of DNS tunneling or C2-over-DNS: the malware encodes data or command identifiers in the subdomain label, which the authoritative DNS server for maliciousdomain.org decodes. A NIDS with DNS anomaly rules monitoring query frequency, unique subdomain count per parent domain, and subdomain label entropy would fire on the first few queries, before a SIEM correlation window accumulates enough events to trigger. A standard perimeter firewall that allows outbound UDP/53 (necessary for legitimate name resolution) cannot inspect the content of DNS queries; blocking all UDP/53 would sever DNS for every shelter user. Targeted responses include DNS sinkholing for the specific domain and NIDS rate-throttling, not blanket UDP/53 blocks. Legitimate update-check traffic resolves known vendor domains, not unique-per-query randomized subdomains.

*Why the others are wrong: **B**, A misbehaving resolver retries the same domain record; it does not generate uniquely randomized subdomains at one-per-second intervals. Syslog monitoring captures system events but does not perform DNS traffic analysis. **C**, DNS amplification involves exploiting open resolvers to flood a victim with large DNS responses; the described pattern is one host querying unique subdomains, the amplification vector is absent. Blocking all UDP/53 outbound disrupts legitimate DNS for all shelter users. **D**, Automatic update checks resolve known vendor domains (e.g., update.microsoft.com) with regular query patterns; unique high-entropy subdomains generated at one-second intervals are not produced by any legitimate update mechanism.*